



سياق أمن المعلومات ومتطلباته ونطاقه

DOCUMENT CLASSIFICATION	Internal / Restricted
DOCUMENT REF	ISMS-DOC-04-1
VERSION	1.0
DATED	12 September 2026
DOCUMENT AUTHOR	XPyte
DOCUMENT OWNER	سارة الحربي - مديرة أمن المعلومات

Contents

البند	العنوان	الصفحة
1	المقدمة	1
2	سياق المنظمة	2
2.1	الأنشطة	3
2.2	الوظائف	4
2.3	المنتجات والخدمات	5
2.4	سلاسل التوريد	7
3	القضايا الداخلية والخارجية	8
3.1	القضايا الداخلية	9
3.2	القضايا الخارجية	9
3.3	شهية المخاطر	9
4	الأطراف المعنية ومتطلباتها	9
4.1	الأطراف المعنية	10
4.2	المتطلبات	10
5	الغرض ونطاق نظام إدارة أمن المعلومات	10
5.1	الغرض	10
5.2	الأثر المحتمل لحادث أمن المعلومات	11
5.3	أهداف أمن المعلومات	11
5.4	نطاق نظام إدارة أمن المعلومات	12
5.4.1	النطاق التنظيمي	12
5.4.2	المنتجات والخدمات	13
5.4.3	الأنشطة	13
5.4.4	الاستثناءات	13

1.1 Introduction (المقدمة)

بنك الأفاق الرقمية ملتزم بحماية أمن معلوماته في مواجهة الحوادث والأحداث غير المرغوبة، وقد طَبَّقَ نظام إدارة أمن المعلومات (ISMS) المتوافق مع ISO/IEC 27001، المعيار الدولي لأمن المعلومات.

الغرض من هذه الوثيقة هو وصف طريقة عمل البنك، والعوامل الداخلية والخارجية المؤثرة عليه، وإبراز النتائج المحتملة لأي خرق أمني. وسيتم تحديث هذه الوثيقة سنوياً على الأقل، وعند حدوث أي تغيير جوهري في المجالات ذات الصلة.

تحدد هذه الوثيقة:

- سياق المنظمة
- القضايا الخارجية والداخلية ذات الصلة ببنك الأفاق الرقمية
- الأطراف المعنية ذات الصلة بنظام إدارة أمن المعلومات
- متطلبات أمن المعلومات لهذه الأطراف
- نطاق نظام إدارة أمن المعلومات، بما في ذلك حدوده وقابليته للتطبيق

1.2 Organizational context

(سياق المنظمة)

سياق بنك الأفاق الرقمية موضح في الأقسام التالية. نظراً لطبيعة العمل سريع التغير في القطاع المصرفي، فإن السياق سيتغير بمرور الوقت، وسيتم مراجعة هذه الوثيقة سنوياً وإدراج أي تغييرات جوهرية.

1.2.1 Activities(الأنشطة)

بنك الأفاق الرقمية هو بنك سعودي يقدم خدمات مصرفية شاملة للأفراد والشركات، ويركز على التحول الرقمي والخدمات المصرفية الإلكترونية.

- **النشاط:** خدمات مصرفية للأفراد والشركات، خدمات رقمية عبر تطبيق "أفاق بلس"، خدمات مصرفية عبر الإنترنت، تحويلات مالية، إدارة استثمارات.
- **الهيكل:** بنك مستقل برئاسة مجلس الإدارة (السيد عبدالله المحيسن) والرئيس التنفيذي (الدكتورة نورة القحطاني).
- **القطاع:** القطاع المصرفي والمالي السعودي.
- **العلاء:** الأفراد (أكثر من 500,000 عميل)، الشركات، الشركات الصغيرة والمتوسطة.
- **المناطق الجغرافية:** المملكة العربية السعودية – الرياض (المقر الرئيسي)، جدة، الدمام، المنطقة الشرقية.
- **عدد الفروع:** 25 فرعاً + 75 جهاز صراف آلي.
- **عدد الموظفين:** حوالي 2,500 موظف.

1.2.2 Functions (الوظائف)

يتكون بنك الأفاق الرقمية من الوظائف التنظيمية التالية:

الإدارة العليا:

- مجلس الإدارة
- الرئيس التنفيذي
- مكتب الرئيس التنفيذي

قطاع الأعمال والمخاطر:

- إدارة المخاطر المؤسسية
- إدارة الالتزام والحوكمة
- إدارة الشؤون القانونية
- إدارة المراجعة الداخلية

قطاع التقنية والعمليات:

- إدارة تقنية المعلومات (البنية التحتية، التطبيقات المصرفية، تطوير البرمجيات، قواعد البيانات، الدعم الفني)
- إدارة أمن المعلومات (حوكمة أمن المعلومات، العمليات الأمنية SOC، الاستجابة للحوادث، تقييم المخاطر والثغرات)
- إدارة العمليات المصرفية

قطاع الموارد البشرية والشؤون الإدارية:

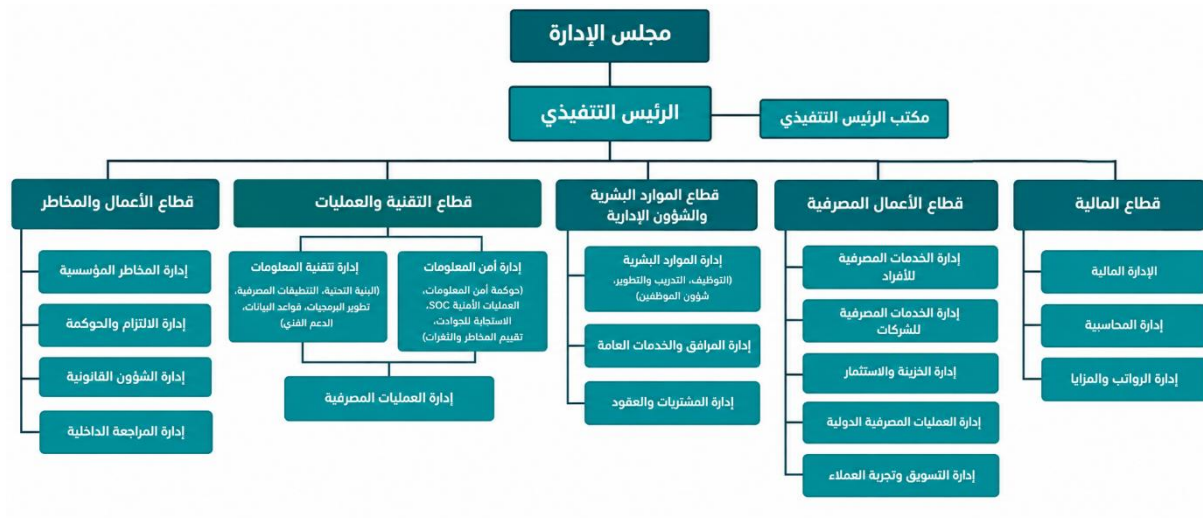
- إدارة الموارد البشرية (التوظيف، التدريب والتطوير، شؤون الموظفين)
- إدارة المرافق والخدمات العامة
- إدارة المشتريات والعقود

قطاع الأعمال المصرفية:

- إدارة الخدمات المصرفية للأفراد
- إدارة الخدمات المصرفية للشركات
- إدارة الخزينة والاستثمار
- إدارة العمليات المصرفية الدولية
- إدارة التسويق وتجربة العملاء

قطاع المالية:

- الإدارة المالية
- إدارة المحاسبة
- إدارة الرواتب والمزايا



1.2.3 Products and services (المنتجات والخدمات)

يقدم بنك الأفاق الرقمية المنتجات والخدمات الرئيسية التالية:

التطبيقات المصرفية الرئيسية:

- تطبيق "أفاق بلس" للهاتف المحمول: التطبيق الرئيسي للخدمات المصرفية عبر الهاتف المحمول، متاح على iOS و Android، يتيح للعملاء إدارة حساباتهم، إجراء التحويلات، دفع الفواتير، والاستثمار.
- منصة "أفاق نت" للخدمات المصرفية عبر الإنترنت: النسخة المبنية على المتصفح من الخدمات المصرفية الإلكترونية.

الأنظمة المصرفية الأساسية:

- نظام المعاملات المصرفية الأساسي (Core Banking System): نظام متكامل لإدارة جميع العمليات المصرفية الأساسية مثل فتح الحسابات، إدارة الودائع، معالجة القروض، وإدارة علاقات العملاء.
- نظام إدارة البطاقات (Card Management System): نظام متخصص لإصدار وإدارة البطاقات الائتمانية وبطاقات الصراف الآلي.
- نظام الدفعات الفورية (Instant Payments System): نظام متصل بشبكة المدفوعات الوطنية لمعالجة التحويلات الفورية على مدار الساعة.

جميع المنتجات والخدمات: تُقدّم لجميع العملاء (أفراد وشركات)، وجميعها تخضع لتنظيم البنك المركزي السعودي (ساما).

1.2.4 Supply chains (سلاسل التوريد)

لتقديم منتجاتنا وخدماتنا لعملائنا، توجد عدة مسارات مهمة لسلاسل التوريد، أهمها:

- مزود خدمة الإنترنت الرئيسي: شركة الاتصالات السعودية.
- مزود الخدمة السحابية: Amazon Web Services (AWS) لبعض الأنظمة غير الحرجة.
- استشاري فحص الثغرات الخارجي: شركة متخصصة في الأمن السيبراني.
- شركة تطوير تطبيقات الهاتف المحمول: متعاقد معها لتطوير جزء من تطبيق "أفاق بلس".
- مزود خدمة إدارة أجهزة الصراف الآلي.
- شركة خدمات نقل الأموال والأمن: مسؤولة عن نقل الأموال بين الفروع.

1.3 Internal and external issues

هناك عدد من القضايا الداخلية والخارجية ذات الصلة بـ **بنك الآفاق الرقمية** والتي تؤثر على قدرة نظام إدارة أمن المعلومات على تحقيق نتائج المرجوة.

1.3.1 Internal issues (القضايا الداخلية)

بالنسبة لعمل **بنك الآفاق الرقمية**، هناك عدد من القضايا الداخلية ذات الصلة، وتشمل:

- **الثقافة التنظيمية:** بعض الموظفين القدامى يرون أن إجراءات أمن المعلومات تعيق سرعة العمل وتضيف بيروقراطية غير ضرورية. ثقافة "الأمن أولاً" لم تترسخ بعد بشكل كامل في جميع مستويات المؤسسة.
- **التنوع الثقافي:** البنك يوظف مزيجاً من الموظفين السعوديين والوافدين من جنسيات مختلفة، مما يخلق تحديات إضافية في التواصل والتوعية الأمنية.
- **دوران الموظفين:** نسبة دوران الموظفين في قسم تقنية المعلومات تبلغ حوالي 12% سنوياً، وهي نسبة متوسطة لكنها تخلق تحديات في الحفاظ على المعرفة المؤسسية المتعلقة بالأمن.
- **الحاجة لتغيير ثقافي تدريجي** يقوده دعم الإدارة العليا.

1.3.2 External issues (القضايا الخارجية)

فيما يتعلق بالبيئة الخارجية التي يعمل فيها **بنك الآفاق الرقمية**، هناك عدد من القضايا الخارجية ذات الصلة، وتشمل:

- **تزايد التهديدات السيبرانية:** يشهد القطاع المالي عالمياً ومحلياً تزايداً مستمراً في التهديدات السيبرانية. تستهدف مجموعات الجرائم الإلكترونية المنظمة البنوك بشكل خاص نظراً للقيمة العالية للبيانات المالية.
- **أبرز التهديدات:**
 - هجمات الفدية (Ransomware) التي تستهدف تشفير بيانات البنك وطلب فدية.
 - هجمات التصيد الاحتيالي المتطورة التي تستهدف موظفي البنك وعملائه.
 - هجمات حجب الخدمة الموزعة (DDoS) التي تهدف إلى تعطيل الخدمات المصرفية الرقمية.
 - هجمات سلسلة التوريد التي تستهدف الموردين والشركاء التقنيين.
 - التهديدات الداخلية من موظفين حاليين أو سابقين.
 - استغلال الثغرات في تطبيقات الهاتف المحمول والخدمات المصرفية عبر الإنترنت.
- **الجهات التنظيمية:** البنك المركزي السعودي (ساما) يفرض متطلبات صارمة على البنوك.
- **التطور التكنولوجي السريع:** الحاجة المستمرة لمواكبة التقنيات الجديدة.

1.3.3 Risk appetite(شهية المخاطر)

تم تصميم نظام إدارة أمن المعلومات لمعالجة المخاطر الرئيسية المحددة لأمن معلومات بنك الأفاق الرقمية. بشكل عام، يمكن القول إن شهية البنك للمخاطر منخفضة (Low).

استراتيجية البنك: تجنّب المخاطر قدر الإمكان، واستثمار الموارد في تخفيف المخاطر المتبقية من خلال تدابير أمن معلومات فعالة. وهذا يتوافق مع طبيعة القطاع المصرفي الذي يتطلب درجة عالية من الامتثال والحماية.

هذا المستوى العام من شهية المخاطر سيُطبّق على تقييمات المخاطر التي تُجرى كجزء من نظام إدارة أمن المعلومات. ومعايير تقييم المخاطر محددة في وثيقة منفصلة هي وثيقة تقييم ومعالجة المخاطر (Risk Assessment and Treatment Process).

1.4 Interested parties and their requirements (الأطراف المعنية ومتطلباتها)

الأطراف الداخلية: مجلس الإدارة، الرئيس التنفيذي، مديرو الإدارات، جميع الموظفين، إدارة المراجعة الداخلية، إدارة الالتزام والشؤون القانونية.

الأطراف الخارجية: البنك المركزي السعودي (ساما)، العملاء، الموظفون السابقون، الموردون، الجهات الحكومية (NCA)، SDAIA، وزارة الداخلية، البنوك المراسلة، شركات التدقيق، شركات التأمين، المساهمون.

1.4.1 Interested parties(الأطراف المعنية)

الطرف المعني هو "شخص أو منظمة يمكن أن تؤثر، أو تتأثر، أو ترى نفسها متأثرة بقرار أو نشاط".

الأطراف المعنية التالية ذات صلة بنظام إدارة أمن المعلومات في بنك الأفاق الرقمية:

الأطراف الداخلية:

- مجلس الإدارة
- الرئيس التنفيذي والإدارة التنفيذية
- مديرو الإدارات والأقسام
- جميع موظفي البنك
- إدارة المراجعة الداخلية
- إدارة الالتزام والشؤون القانونية

الأطراف الخارجية:

- البنك المركزي السعودي (ساما)
- العملاء (الأفراد والشركات)
- الموظفون السابقون والمتقاعدون
- الموردون والشركاء التقنيون
- الجهات الحكومية الأخرى (هيئة البيانات والذكاء الاصطناعي، الهيئة الوطنية للأمن السيبراني، وزارة الداخلية)
- البنوك المراسلة والمؤسسات المالية الدولية

- شركات التدقيق الخارجي
- شركات التأمين السيبراني
- المساهمون والمستثمرون

1.4.2 Requirements (المتطلبات)

1.5

هل يتم تلبيتها من خلال ISMS؟	المتطلبات	الطرف المعني
نعم، من خلال تجنب الخروقات وحماية السمعة	حماية سمعة البنك ومصالح المساهمين، تقارير موجزة عن المخاطر	مجلس الإدارة
نعم، من خلال التقارير ومؤشرات الأداء	نظام ISMS متكامل لدعم القرارات، تقارير أداء دورية	الرئيس التنفيذي والإدارة التنفيذية
نعم، من خلال السياسات والتدريب	سياسات وإجراءات واضحة، دعم من فريق أمن المعلومات	مديرو الإدارات
نعم، من خلال التوعية والتدريب	فهم مسؤولياتهم، بيئة عمل آمنة، قنوات إبلاغ	جميع الموظفين
نعم، من خلال توثيق ISMS	وصول كافٍ للأنظمة والوثائق للتدقيق	إدارة المراجعة الداخلية
نعم، من خلال التوثيق والامتثال	الامتثال للمتطلبات القانونية والتنظيمية	إدارة الالتزام والشؤون القانونية
نعم، من خلال الامتثال الكامل	تطبيق إطار عمل شامل للأمن السيبراني، الإبلاغ الفوري عن الحوادث، تقييمات منتظمة للمخاطر، حماية بيانات العملاء، اختبارات اختراق دورية، خطة استمرارية أعمال	البنك المركزي السعودي (ساما)
نعم، من خلال ضوابط الحماية والإشعار	حماية كاملة لبياناتهم، خدمات رقمية متاحة وأمنة، إشعار فوري عند الخرق	العملاء
نعم، من خلال ضوابط حماية البيانات	حماية بياناتهم الشخصية واستمرار حماية الرواتب	الموظفون السابقون والمتقاعدون
نعم، من خلال اتفاقيات الموردين	التزام البنك بسياسة الاستخدام المقبول، متطلبات أمنية واضحة	الموردون والشركاء
نعم، من خلال الامتثال القانوني	الامتثال لنظام حماية البيانات الشخصية، التعاون في التحقيقات	الجهات الحكومية
نعم، من خلال الامتثال للمعايير	معايير أمنية دولية، ضمانات لأنظمة البنك	البنوك المراسلة والمؤسسات الدولية
نعم، من خلال التوثيق الكامل	وصول كافٍ للأنظمة والوثائق، نظام إدارة موثق	شركات التدقيق الخارجي
نعم، من خلال تقييمات المخاطر	معلومات دقيقة عن وضع الأمن السيبراني	شركات التأمين السيبراني
نعم، من خلال التقارير الدورية	حماية قيمة استثماراتهم، الشفافية في إدارة المخاطر	المساهمون والمستثمرون

المتطلبات القانونية والتنظيمية المعمول بها:

- نظام حماية البيانات الشخصية السعودي (PDPL)
- متطلبات البنك المركزي السعودي (ساما) للأمن السيبراني
- متطلبات الهيئة الوطنية للأمن السيبراني (NCA)
- معايير PCI DSS لمعالجة بطاقات الدفع
- المعايير المصرفية الدولي

1.6 Purpose and scope of the ISMS(الغرض والنطاق)

1.6.1 Purpose (الغرض)

الغرض من نظام إدارة أمن المعلومات في بنك الآفاق الرقمية هو:

1. فهم احتياجات البنك وضرورة إنشاء سياسة وأهداف لإدارة أمن المعلومات.
2. تنفيذ وتشغيل الضوابط والتدابير لإدارة القدرة الإجمالية للبنك على إدارة حوادث أمن المعلومات.
3. مراجعة وتقييم أداء وفعالية نظام إدارة أمن المعلومات.
4. التحسين المستمر لأمن معلومات البنك بناءً على القياس الموضوعي.

ينطبق هذا الغرض على نطاق نظام إدارة أمن المعلومات كما هو محدد أدناه.

1.6.2 Potential impact of an information security incident(الأثر المحتمل)

الأثر الناتج عن أي حادث معين سيعتمد بوضوح على طبيعته، ويتم إجراء تقييم شامل للمخاطر لتقييم وتخفيف تلك التي يمكن تحديدها بشكل معقول. بشكل عام، سيظهر التأثير المحتمل لعدم القدرة على أداء العمليات التجارية العادية في واحد أو أكثر من المجالات الرئيسية التالية (كما اتضح من الحوادث السابقة):

- خسارة إيرادات المبيعات: كما في حادثة انقطاع الخدمات المصرفية الرقمية (القسم 4.1) التي تسببت في 5,000 شكوى.
- خطر على الحياة أو الصحة والسلامة: غير مطبق بشكل مباشر، لكن انقطاع الخدمات المصرفية قد يؤثر على العملاء.
- فقدان السمعة/ثقة العملاء: كما في حادثة انتهاء صلاحية شهادة SSL (القسم 4.4) التي تسببت في أضرار سمعة كبيرة على وسائل التواصل الاجتماعي.
- عدم القدرة على الوفاء بالالتزامات القانونية: كما في حادثة فقدان جهاز الحاسوب المحمول (القسم 4.3) التي أدت إلى غرامة تنظيمية.
- خرق الالتزامات التعاقدية: كما في حادثة هجوم التصيد (القسم 4.2) التي استهدفت موظفي الإدارة المالية.
- فقدان فرص العمل: نتيجة فقدان ثقة العملاء.
- الغرامات والعقوبات الأخرى: كما في حادثة فقدان الجهاز المحمول (القسم 4.3) التي كلفت البنك غرامة تنظيمية وتكاليف إضافية.

1.6.3 Information security objectives (أهداف أمن المعلومات)

بناءً على المتطلبات والقضايا المبينة في هذه الوثيقة، يتم تحديد الأهداف الرئيسية التالية لأمن المعلومات في بنك الآفاق الرقمية:

الرقم	الهدف
الهدف 1	الامتثال الكامل للمتطلبات التنظيمية للبنك المركزي السعودي (ساما)
الهدف 2	حماية قوية لبيانات العملاء الشخصية والمالية
الهدف 3	توفير عالٍ للخدمات المصرفية الرقمية
الهدف 4	آليات واضحة للإبلاغ عن الحوادث والتصعيد
الهدف 5	توثيق شامل لجميع عمليات وإجراءات النظام
الهدف 6	تدريب وتوعية مستمرة لجميع الموظفين
الهدف 7	إدارة فعالة للمخاطر المرتبطة بالموردين والأطراف الثالثة
الهدف 8	خطط معتمدة ومختبرة لاستمرارية الأعمال
الهدف 9	تقارير دورية وشفافية عن أداء النظام

1.6.4 Scope of the ISMS (نطاق ISMS)

النطاق المحدد لنظام إدارة أمن المعلومات في بنك الآفاق الرقمية يأخذ في الاعتبار القضايا الداخلية والخارجية المشار إليها في الأقسام 3.1 و 3.2 من هذه الوثيقة، والمتطلبات المشار إليها في القسم 4. كما يعكس احتياجات الأطراف المعنية والمتطلبات القانونية والتنظيمية المعمول بها.

1.6.4.1 Organizational (النطاق التنظيمي)

شمل نظام إدارة أمن المعلومات البنك بأكمله بجميع إداراته وأقسامه، بما في ذلك:

- الإدارة العليا: مجلس الإدارة، الرئيس التنفيذي، مكتب الرئيس التنفيذي.
- قطاع الأعمال والمخاطر: المخاطر المؤسسية، الالتزام والحوكمة، الشؤون القانونية، المراجعة الداخلية.
- قطاع التقنية والعمليات: تقنية المعلومات (البنية التحتية، التطبيقات، التطوير، قواعد البيانات، الدعم الفني)، أمن المعلومات (الحوكمة، SOC، الاستجابة للحوادث، تقييم المخاطر)، العمليات المصرفية.
- قطاع الموارد البشرية والشؤون الإدارية: الموارد البشرية، المرافق، المشتريات.
- قطاع الأعمال المصرفية: الأفراد، الشركات، الخزينة والاستثمار، العمليات الدولية، التسويق.
- قطاع المالية: المالية، المحاسبة، الرواتب والمزايا.

المواقع الجغرافية المشمولة:

- المقر الرئيسي – الرياض (المبنى المكون من 12 طابقاً)
- مركز البيانات الرئيسي – الرياض
- مركز التعافي من الكوارث – جدة
- 25 فرعاً مصرفياً (10 الرياض، 8 جدة، 7 الدمام والمنطقة الشرقية)
- 75 جهاز صراف آلي في المواقع المستقلة

1.6.4.2 Products and services (المنتجات والخدمات)

المنتجات والخدمات التالية ضمن نطاق نظام إدارة أمن المعلومات:

- تطبيق "آفاق بلس" للهواتف المحمول (iOS و Android)
- منصة "آفاق نت" للخدمات المصرفية عبر الإنترنت
- نظام المعاملات المصرفية الأساسي (Core Banking System)
- نظام إدارة البطاقات (Card Management System)
- نظام الدفعات الفورية (Instant Payments System)
- جميع الخدمات المصرفية المقدمة عبر الفروع وأجهزة الصراف الآلي
- الأنظمة الداخلية الداعمة: ERP، CRM، Office 365، GitLab، Jira

1.6.4.3 Activities (الأنشطة)

- الأنشطة التالية ضمن نطاق نظام إدارة أمن المعلومات:
- تشغيل وصيانة الأنظمة المصرفية الأساسية
- تطوير وصيانة التطبيقات المصرفية
- إدارة الشبكات والبنية التحتية لتقنية المعلومات
- إدارة قواعد البيانات المصرفية
- إدارة مركز البيانات الرئيسي ومركز التعافي من الكوارث
- العمليات الأمنية (SOC) والاستجابة للحوادث
- إدارة المخاطر والثغرات الأمنية
- إدارة الهوية والوصول
- إدارة الموردين والعلاقات مع الأطراف الثالثة
- التوعية والتدريب الأمني للموظفين
- إدارة استمرارية الأعمال والتعافي من الكوارث
- إدارة الامتثال والمتطلبات التنظيمية

1.6.4.4 Exclusions (الاستثناءات)

المناطق التالية مستبعدة تحديداً من نطاق نظام إدارة أمن المعلومات:

- إدارة المرافق والخدمات العامة: (باستثناء أنظمة التحكم في الوصول المادي والمراقبة) – لأنها لا تتعامل مع معلومات حساسة بشكل مباشر.
- بعض وظائف إدارة التسويق: (باستثناء بيانات العملاء المستخدمة في الحملات التسويقية) – لأنها أقل حساسية من الناحية المعلوماتية.